



SIMATS
ENGINEERING



SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

CO5 ASSESSMENT TOOL 1

Name : S.Deepadharshan

Reg No : 192472046

Course Code : ITA1408

Course Name : Ethical Hacking

Submitted to : Dr Parthiban S

INDUSTRY PROBLEM TASK

Questions :

1. Analyze the extent of a Windows domain network attack by calculating the number of systems compromised during the initial stage and estimating the spread through lateral movement. Evaluate the risk of large-scale compromise and identify the vulnerability that should be prioritized for immediate mitigation.
2. Determine the expected number of systems successfully compromised through exposed RPC services and calculate the expected number of detection alerts. Evaluate whether a stealthy attacker would proceed with exploitation or adopt alternative strategies.
3. Evaluate the probability that at least one internet-exposed Linux service is vulnerable and calculate the overall probability of full system compromise considering weak file permissions and privilege escalation.
4. Calculate the probability of unauthorized NFS access from the three internal subnets and determine the overall probability of complete system compromise. Evaluate the effectiveness of restricting NFS access to a single subnet.
5. Compute the number of records that can be extracted through a SQL injection attack before it is blocked, determine the percentage of data compromised, and estimate the sensitive records exposed. Evaluate the severity of the breach and the effectiveness of the detection mechanism.

QUESTION 1

Problem Statement

A financial organization has a Windows domain network containing 150 interconnected systems. Attackers have exploited NULL sessions, open RPC services, and misconfigured shared folders. 45% of systems allow anonymous enumeration, and 60% of those are susceptible to SMB-based lateral movement. Each compromised system can attempt to access 3 additional systems with a success probability of 0.3 per attempt.

Solution

Given:

- Total systems = 150
- Systems allowing anonymous enumeration = 45%
- Systems susceptible to SMB lateral movement = 60% of anonymously enumerable systems
- Attempts per compromised system = 3
- Success probability per attempt = 0.3

Step 1: Initial systems exposed

$$150 \times \frac{45}{100} = 67.5$$

Therefore, the expected number of systems allowing anonymous enumeration is: $67.5 \approx 68$ systems

Step 2: Systems susceptible to SMB lateral movement

$$67.5 \times 0.60 = 40.5$$

Therefore, approximately: $40.5 \approx 41$ systems are susceptible to SMB-based lateral movement.

Step 3: Expected second-stage spread

Each compromised system makes 3 attempts with a success probability of 0.3.

$$40.5 \times 3 \times 0.3 = 36.45$$

Therefore, the expected second-stage spread is: **$36.45 \approx 36$ systems**

Step 4: Total expected compromised systems

$$40.5 + 36.45 = 76.95$$

Approximately:

77 systems

may be compromised after the two stages.

Step 5: Determine whether the network faces a large-scale compromise

The threshold for large-scale compromise is 70% of 150 systems.

$$150 \times 0.70 = 105$$

Expected compromised systems:

$$76.95$$

Percentage compromised:

$$\frac{76.95}{150} \times 100 = 51.3\%$$

Since $51.3\% < 70\%$, the attack does not exceed the specified large-scale compromise threshold.

Vulnerability to Prioritize

Weak shares should be prioritized for immediate mitigation. Misconfigured shared folders can directly provide unauthorized access and facilitate SMB-based lateral movement. The analysis shows that a significant number of systems are susceptible to this stage of the attack.

NULL sessions should also be restricted because they enable anonymous enumeration, while unnecessary RPC exposure should be reduced through proper firewall and access-control rules.

Conclusion

The expected attack progression is approximately 40.5 systems in the initial exploitable group and 36.45 additional systems through lateral movement, giving an estimated total of 76.95 systems or 51.3% of the network. Although this is below the 70% large-scale compromise threshold, the risk is still serious because more than half of the network could potentially be affected.

QUESTION 2

Problem Statement

An enterprise has 120 systems, of which 70 expose RPC services. 40% of these systems are vulnerable to known exploits, and each vulnerable system has a 0.5 probability of successful exploitation. Each exploitation attempt has a detection probability of 0.25.

Solution

Given:

- Total systems = 120
- RPC-exposed systems = 70
- Vulnerable systems = 40%
- Successful exploitation probability = 0.5
- Detection probability = 0.25

Step 1: Number of vulnerable systems

$$70 \times 0.40 = 28$$

Therefore:

28 systems are expected to be vulnerable.

Step 2: Expected successfully compromised systems

$$28 \times 0.50 = 14$$

Therefore, the expected number of successfully compromised systems is:

14 systems

Step 3: Expected number of detection alerts

Each of the 28 exploitation attempts has a 0.25 detection probability.

$$28 \times 0.25 = 7$$

Therefore, the expected number of detection alerts is: 7 alerts

Step 4: Stealth analysis

The attacker could potentially compromise 14 systems, but approximately 7 detection alerts are expected during the exploitation process.

This means the attack has a significant probability of being detected. An attacker whose primary objective is to remain stealthy would therefore be less likely to directly exploit all vulnerable RPC systems. Instead, the attacker may prefer quieter attack strategies that reduce the probability of detection.

Conclusion

The expected number of successfully compromised systems is 14, while the expected number of detection alerts is 7. Because the exploitation process can generate a considerable number of alerts, a stealth-focused attacker would have strong reasons to avoid aggressive exploitation and consider less detectable alternatives.

QUESTION 3

Problem Statement

A cloud-hosted Linux server has four internet-exposed critical services with vulnerability probabilities of 0.3, 0.2, 0.25, and 0.15. Weak file permissions can be exploited with a probability of 0.5 after initial access is gained.

Solution

Given:

- Service 1 vulnerability probability = 0.3
- Service 2 vulnerability probability = 0.2
- Service 3 vulnerability probability = 0.25
- Service 4 vulnerability probability = 0.15
- Weak-permission exploitation probability = 0.5

Step 1: Probability that no service is vulnerable

The probability that each service is **not vulnerable** is:

$$1 - 0.3 = 0.7$$

$$1 - 0.2 = 0.8$$

$$1 - 0.25 = 0.75$$

$$1 - 0.15 = 0.85$$

Assuming independence:

$$\begin{aligned} P(\text{no vulnerable service}) &= 0.7 \times 0.8 \times 0.75 \times 0.85 \\ &= 0.357 \end{aligned}$$

Step 2: Probability that at least one service is vulnerable

$$\begin{aligned} P(\text{at least one}) &= 1 - P(\text{none}) \\ &= 1 - 0.357 \\ &= \boxed{0.643} \end{aligned}$$

Therefore:

Probability of at least one vulnerable service = 64.3%

Step 3: Overall probability of full system compromise

Once initial access is obtained, the probability of privilege escalation through weak permissions is 0.5.

Therefore:

$$P(\text{full compromise}) = 0.643 \times 0.5$$

$$= \boxed{0.3215}$$

Therefore:

Overall probability of full system compromise = 32.15%

Step 4: Risk evaluation

Strengthening file permissions would reduce the probability of privilege escalation after initial access. However, it would not eliminate the initial attack risk because the probability of at least one vulnerable service is still 64.3%.

Therefore, securing file permissions alone is not sufficient. Internet-facing services should also be patched, hardened, monitored, and restricted wherever possible.

Conclusion

The probability that at least one service is vulnerable is 64.3%, while the estimated overall probability of complete compromise is 32.15%. Strengthening file permissions is important, but it must be combined with service hardening and vulnerability remediation to significantly reduce the overall risk.

QUESTION 4

Problem Statement

An organization uses NFS across three internal subnets. The unauthorized access probabilities are 0.4, 0.3, and 0.2 respectively. Once access is obtained, the probability of privilege escalation to root is 0.7.

Solution

Given:

- Subnet 1 unauthorized access probability = 0.4
- Subnet 2 unauthorized access probability = 0.3
- Subnet 3 unauthorized access probability = 0.2
- Root privilege escalation probability = 0.7

Step 1: Probability that no subnet gains unauthorized access

$$P(\text{no access}) = (1 - 0.4)(1 - 0.3)(1 - 0.2)$$

$$= 0.6 \times 0.7 \times 0.8$$

$$= 0.336$$

Step 2: Probability that at least one subnet gains unauthorized access

$$P(\text{at least one access}) = 1 - 0.336$$

$$= \boxed{0.664}$$

Therefore:

Probability of unauthorized NFS access = 66.4%

Step 3: Overall probability of complete system compromise

The probability of privilege escalation after obtaining access is 0.7.

$$\begin{aligned} P(\text{complete compromise}) &= 0.664 \times 0.7 \\ &= \boxed{0.4648} \end{aligned}$$

Therefore:

Overall probability of complete compromise = 46.48%

Step 4: Effectiveness of restricting NFS to one subnet

Restricting access to only one subnet can substantially reduce the attack surface.

The safest option among the three is the subnet with the lowest unauthorized access probability:

$$P = 0.2$$

If only this subnet is permitted:

$$\begin{aligned} P(\text{complete compromise}) &= 0.2 \times 0.7 \\ &= \boxed{0.14} \end{aligned}$$

Therefore, the complete compromise probability could be reduced to:

14%

compared with the original 46.48%.

Conclusion

The probability of at least one subnet gaining unauthorized NFS access is 66.4%, and the overall probability of complete compromise is 46.48%. Restricting NFS access to a single, properly secured subnet can significantly reduce the risk. Therefore, limiting NFS exposure, combined with strong authentication and access controls, is recommended.

QUESTION 5

Problem Statement

An e-commerce platform has 50,000 user records, of which 30% are sensitive. A successful SQL injection attack can extract 500 records per second, but the application firewall blocks the attack after 40 seconds.

Solution

Given:

- Total records = 50,000
- Sensitive records = 30%
- Extraction rate = 500 records/second
- Attack duration before blocking = 40 seconds

Step 1: Total records extracted

$$\begin{aligned}\text{Records extracted} &= \text{Extraction rate} \times \text{Time} \\ &= 500 \times 40 \\ &= \boxed{20,000}\end{aligned}$$

Therefore, 20,000 records can be extracted before the attack is blocked.

Step 2: Percentage of total data compromised

$$\begin{aligned}\frac{20,000}{50,000} \times 100 \\ &= \boxed{40\%}\end{aligned}$$

Therefore, 40% of the total database could be compromised.

Step 3: Number of sensitive records exposed

Sensitive records:

$$50,000 \times 0.30 = 15,000$$

Since 30% of the extracted records are assumed to be sensitive:

$$20,000 \times 0.30 = 6,000$$

Therefore:

6,000 sensitive records could be exposed.

Step 4: Severity of the breach

The breach is high severity because an attacker can extract approximately 20,000 records, representing 40% of the entire database. Furthermore, approximately 6,000 sensitive records could be exposed.

Step 5: Evaluation of the detection mechanism

The application firewall is useful because it detects and blocks the attack after 40 seconds. However, allowing 20,000 records to be extracted before blocking is not sufficient protection for critical data.

A stronger security approach should include:

- Secure parameterized queries and prepared statements
- Input validation
- Web application firewall rules
- Database access controls
- Least-privilege database accounts
- Continuous monitoring and alerting
- Regular SQL injection security testing

Conclusion

The attacker can extract 20,000 records, which represents 40% of the database, including an estimated 6,000 sensitive records. Therefore, the breach is severe. Although the existing detection mechanism limits the duration of the attack, it is not sufficient by itself to protect critical data. Preventing SQL injection at the application and database layers is essential.

OVERALL CONCLUSION

The five scenarios demonstrate that security risks can propagate through interconnected vulnerabilities and weak configurations. Quantitative analysis shows that: